

Seguridad en Bases de Datos

SGBD - Funciones

- Almacenamiento y Consulta
- Integridad
- **Seguridad**
- Concurrencia
- Recuperación
- Soporte transaccional

Seguridad

Seguridad de la información- > proteger a los sistemas de información

Seguridad - Objetivos

- Confidencialidad
- Integridad
- Disponibilidad (para personas autorizadas)
- No repudio (irrenunciabilidad)

Seguridad – Ventanas de acceso

- Alteraciones en la configuración
- SQL Injection
- Sniffing
- Robo de password

Seguridad – Amenazas

- Accesos no autorizados
- Alteración de la información
- Destrucción de la información

Seguridad – Acciones

Gestionar accesos -> cada usuario lo que necesita

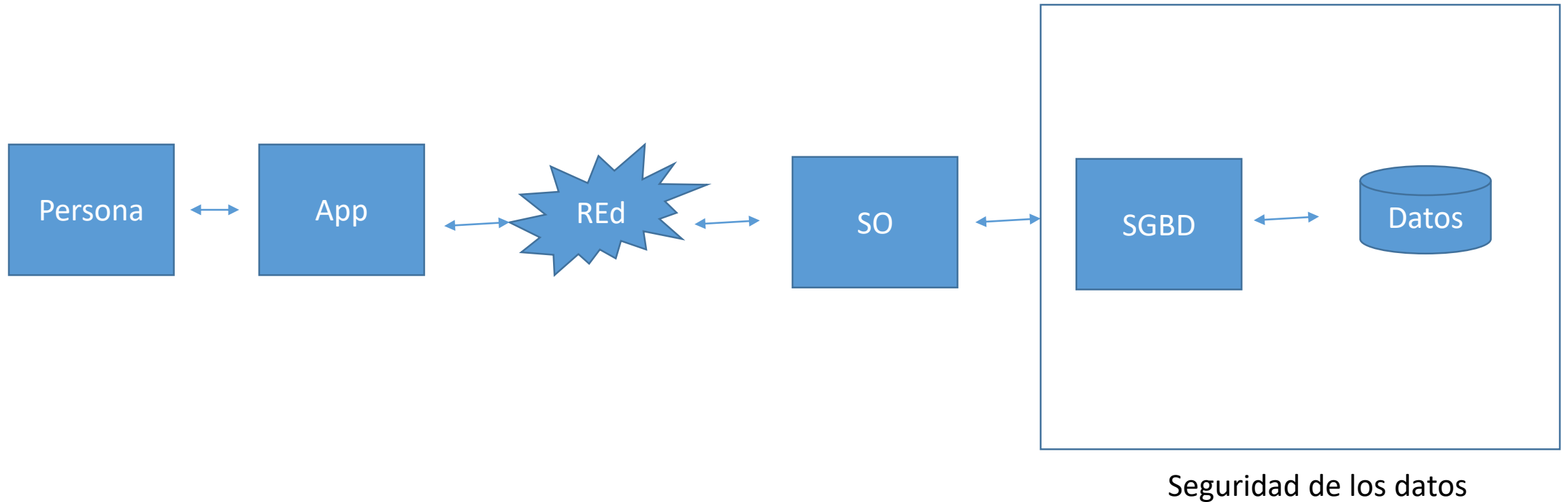
Log de transacciones -> Trazabilidad

Backup -> recuperación

Encriptación

- En la DB -> protege de lecturas no autorizadas
- En las Redes -> Mitiga las fugas mediante sniffing

Seguridad - Actores



Política de seguridad de datos (data security policy)

Seguridad - Métodos

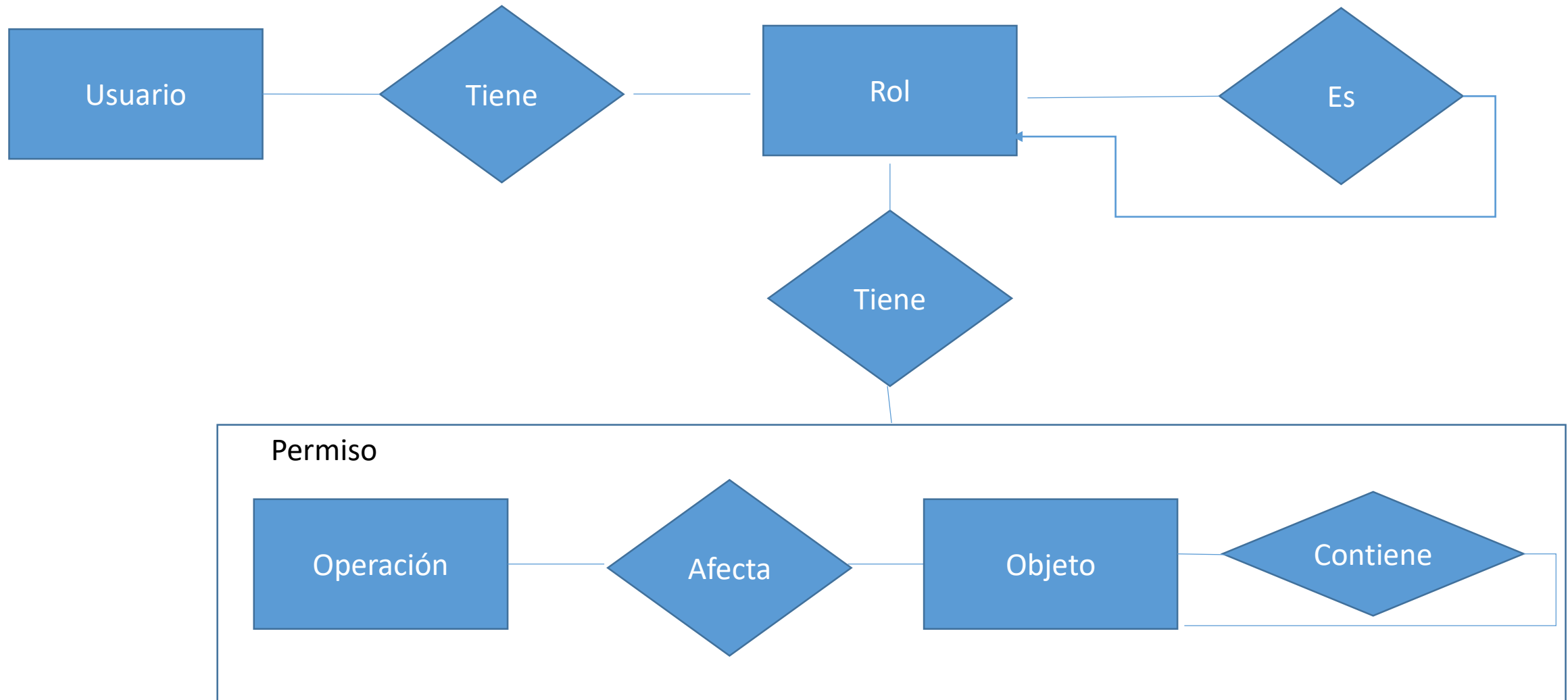
Sistemas de control de acceso a la información

- MAC - Control de acceso obligatorio (owner del objeto)
- DAC - Control de acceso discrecional (sistema $\leftrightarrow$ objetos)
- **RBAC - Control de acceso basado en roles**

Seguridad - RBAC

- Usuarios
- Roles
- Objetos
- Operaciones
- Permisos

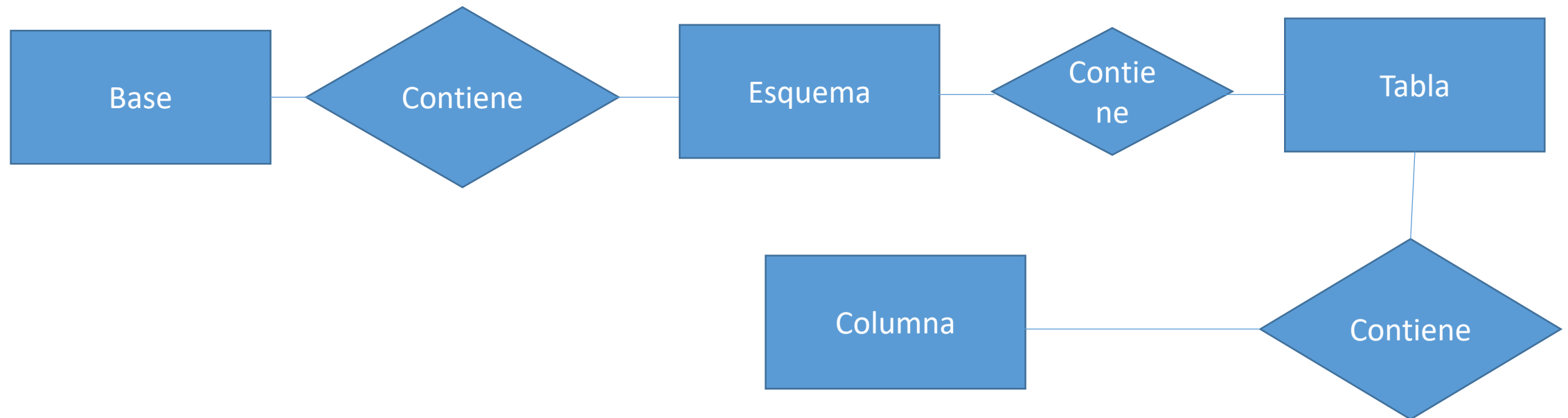
Seguridad - RBAC



Seguridad - RBAC

- Jerarquía de roles y objetos
- Criterio del menor privilegio posible
- División de responsabilidades
- Abstracción de datos

Seguridad - RBAC



Seguridad - SQL

Log de transacciones -> Trazabilidad

Seguridad - SQL

GRANT <permiso> ON <objeto> TO <adquirente>

Permiso: select , update, insert , delete, exec

Objeto: tabla, vista, Stored Procedure

Adquirente: usuario, rol

Seguridad - SQL

GRANT <permiso> ON <objeto> TO <adquirente> with grant option

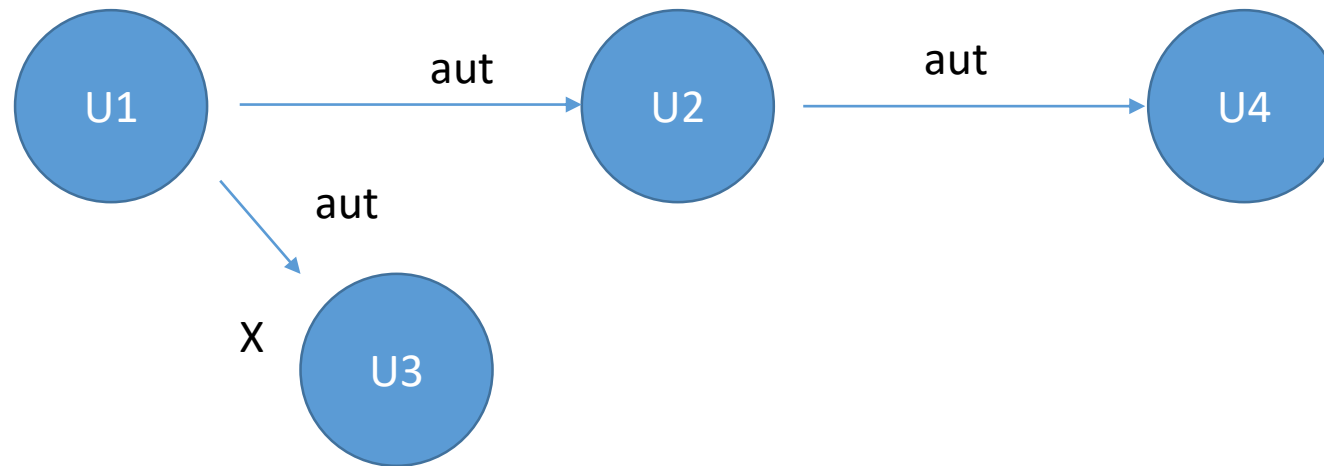
Permiso para conceder permisos

Seguridad - SQL

GRANT UPDATE ON Clientes TO miUsuario

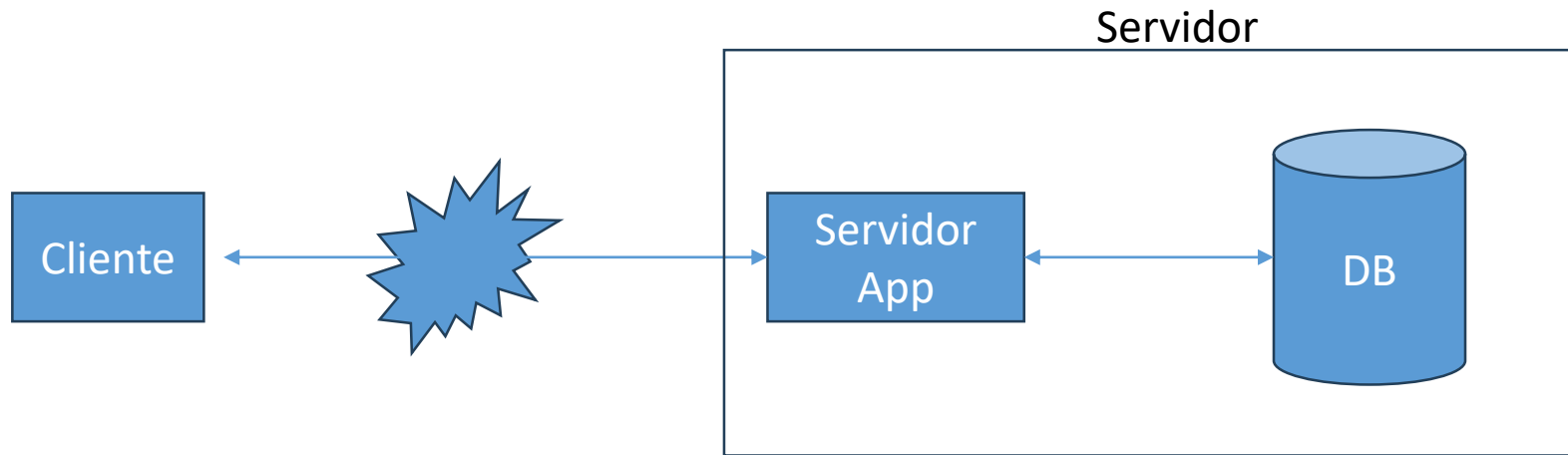
GRANT EXEC ON ObtenerClientes TO miUsuario

Seguridad – Grafo de autorizaciones

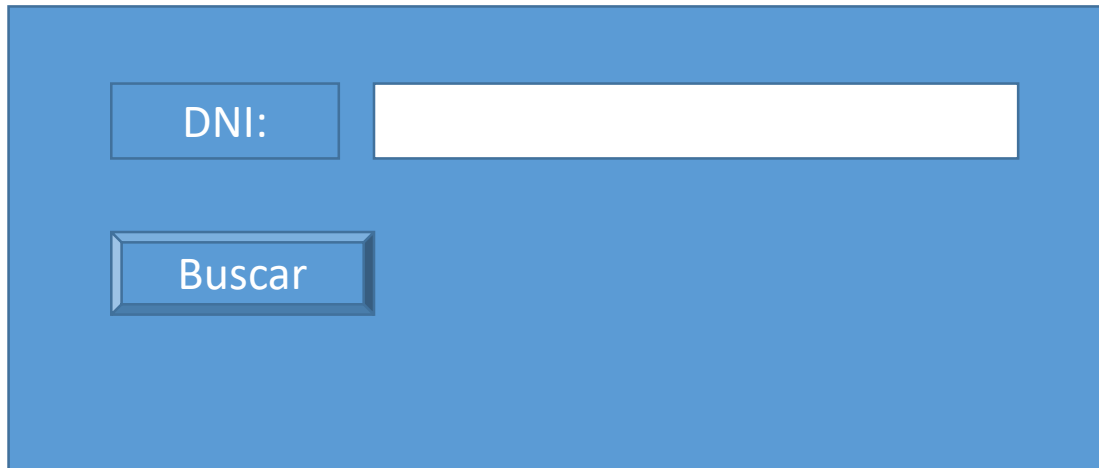


Seguridad – SQL Injection

Aplicación Web



Seguridad – SQL Injection

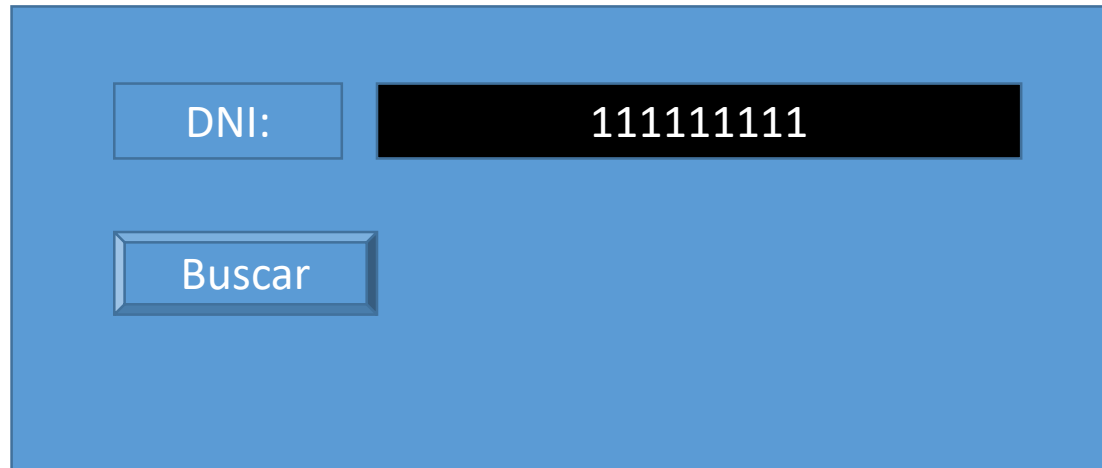


DNI:

Buscar

```
f"SELECT * FROM Personas WHERE dni= '{dni}' "
```

Seguridad – SQL Injection

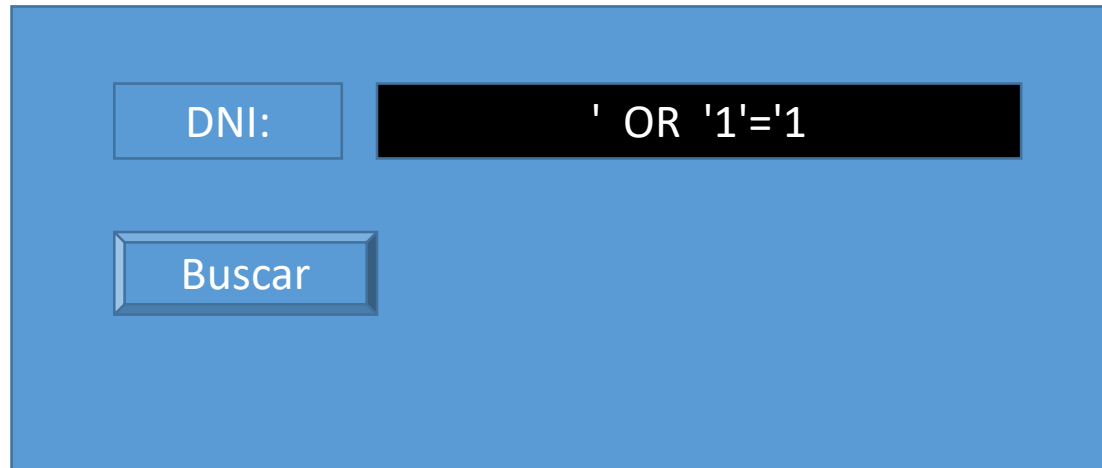


DNI: 11111111

Buscar

```
SELECT * FROM Personas WHERE dni= '11111111'
```

Seguridad – SQL Injection

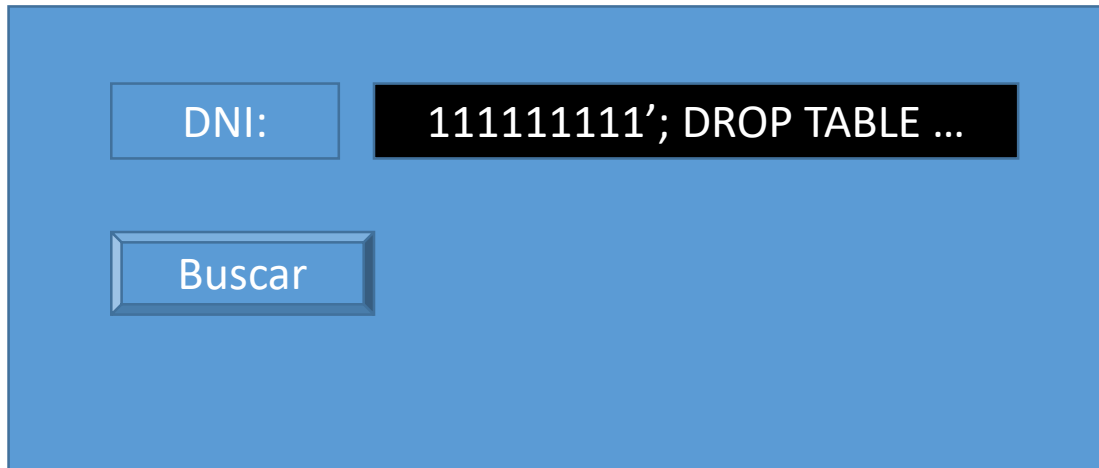


DNI:

Buscar

```
SELECT * FROM Personas WHERE dni= ' ' OR '1'='1'
```

Seguridad – SQL Injection



DNI: 11111111'; DROP TABLE ...

Buscar

```
SELECT * FROM Personas WHERE dni= ' 11111111';  
DROP TABLE
```

Seguridad – SQL Injection

Como evitarlo

- Validaciones fuertes
- No concatenar strings
- Usar stored procedures

Preguntas

<https://kahoot.it>

Trabajo en clase

Diseñar un esquema de seguridad Para una Base de datos

1. Definir Base de datos
2. Definir usuarios
3. Definir permisos

<https://padlet.com/jcabrera150/mi-padlet-estelar-3zyqcq98z6wmri58>